APPLICATION SECURITY REVIEW

Acme Leave Tracker

Version 1.4.0 | Employee leave and absence tracker

Approved with conditions

Staging and internal pilot approved. The access-control finding (LV-01) must be fixed and verified before production go-live.

Review ticket	ASR-2026-038
Application tier	Tier 2 (important)
Data classification	Confidential (employee PII, health-related notes)
Product owner	Priya Nair (HR Operations Manager)
Technical lead	Tomas Lindqvist
Hosting	AWS eu-west-1 (ECS, RDS PostgreSQL, S3)
Technology	Python 3.12, PostgreSQL, Docker
Review window	Requested 2026-08-25; testing 2026-09-02 to 2026-09-11; report issued 2026-09-15
Reviewer	AppSec Review Team (demo)
Method	Threat modelling, automated pipeline (secrets, SAST, SCA, IaC, container, DAST), manual code review and authenticated testing; OWASP ASVS 4.0.3 and OWASP Top 10 (2021).

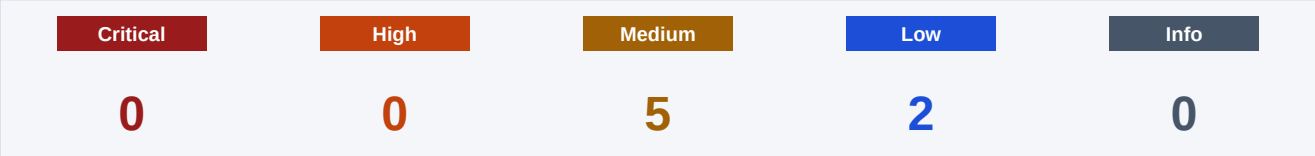
This is a demonstration document. The application, company, people and findings are fictional; the code excerpts and pipeline results are real output from the demo apps in this repository.

1. Executive summary

The Leave Tracker lets employees request time off and lets HR administrators export leave data. Records include leave type and free-text notes that can contain health information, so the app is classed Tier 2 with Confidential data.

The review found **7 findings: 0 Critical, 0 High, 5 Medium and 2 Low** by CVSS. The one priority-P1 item is **LV-01, an insecure direct object reference**: any authenticated employee can read any other employee's leave record, including medical notes, by changing the id in the URL. Scored 6.5 (Medium) on CVSS, it is rated P1 because of the sensitivity of the data.

The pipeline gate **passed** (no Critical or High tool findings, four Medium within the limit of five). That is the expected outcome and also the limitation: no scanner can know that employee 1 should not read employee 2's record. This is the case for keeping a manual review in the process.



Findings by severity (CVSS v3.1 base score)

Top risk drivers	Missing object-level authorisation (IDOR); Health-related notes in leave records; Predictable reset tokens and verbose errors
Pipeline gate	PASS (expected: PASS)
Decision	**Approved with conditions**. Staging and internal pilot approved. The access-control finding (LV-01) must be fixed and verified before production go-live.
Re-test	Targeted re-test of LV-01 requested before go-live (target 2026-09-30).

Conditions of approval

- LV-01 must be fixed and verified before any production user data is loaded.
- Remaining findings tracked in the backlog with the dates above.
- Pipeline gate remains a required check on main.

2. Scope and approach

In scope

- Application source (app.py), 79 lines
- Dependency manifest, container build, Terraform
- Authenticated dynamic testing with two employee accounts and one HR account

Out of scope

- Corporate SSO configuration (reviewed separately)
- HRIS integration (batch file, reviewed in ASR-2026-029)

3. Architecture and trust boundaries

Employees and HR staff authenticate via SSO and call the API with a bearer token. The service queries PostgreSQL with parameterised SQL and stores attachments in an encrypted bucket. In this demo build the token table is hard-wired to stand in for the SSO integration.

Good practices observed

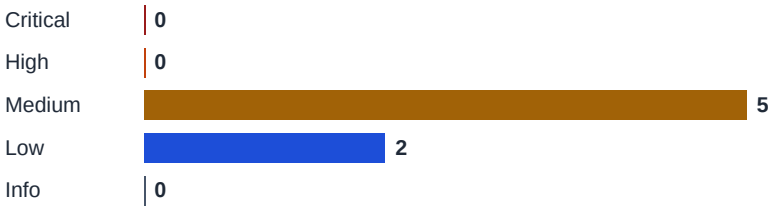
- All SQL uses placeholders; no injection found.
- Role check enforced on the HR export route.
- Database and bucket encrypted; database not public.
- Container runs as non-root.
- X-Content-Type-Options set.
- No secrets in source.

4. Threat model (STRIDE)

Threats were enumerated per trust boundary. 'Assessment' describes the control state found during the review.

Category	Threat	Existing control	Assessment	Findings
Spoofing	Bearer tokens from SSO; demo stub is hard-wired	SSO in production	**Partial**	LV-04
Tampering	Parameterised SQL on every query	Placeholders	**Mitigated**	-
Repudiation	No audit event for exports	Request logs only	**Gap**	LV-07
Information disclosure	IDOR on /leave/{id}; stack traces returned	Role check on export only	**Gap**	LV-01, LV-03
Denial of service	Small internal user base; ALB in front	Platform limits	**Partial**	-
Elevation of privilege	HR role enforced on export; token derived from SSO group	Role check	**Mitigated**	-

5. Findings summary



ID	Finding	Severity	CVSS	Priority	Source	Due
LV-01	Insecure direct object reference on leave records	**Medium**	6.5	P1	Manual review (authenticated test)	Before production
LV-02	Reset tokens generated with a non-cryptographic RNG	**Medium**	5.9	P2	Pipeline (SAST)	30 days
LV-03	Stack traces returned to the client	**Medium**	5.3	P2	Pipeline (SAST)	30 days
LV-04	Session cookie lacks Secure and HttpOnly	**Medium**	5.9	P2	Pipeline (SAST)	30 days
LV-05	requests 2.25.1 has a known advisory (CVE-2023-32681)	**Medium**	6.1	P2	Pipeline (SCA)	30 days
LV-06	Missing CSP and X-Frame-Options; no container health check	**Low**	3.1	P3	Pipeline (DAST, container scan)	60 days
LV-07	No audit trail for HR exports	**Low**	2.7	P3	Manual review	60 days

Priority reflects business urgency and can exceed what CVSS alone implies (P0 fix now, P1 before release/go-live, P2 within 30 days, P3 backlog).

6. Detailed findings

LV-01 Insecure direct object reference on leave records	MEDIUM
CVSS	6.5 (CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N)
Classification	CWE-639 | A01:2021 Broken Access Control
Priority / owner / due	P1 | Tomas Lindqvist | Before production
Detected by	Manual review (authenticated test)
Description	GET /leave/{id} returns the record for any id to any authenticated user. Logged in as employee 1, requesting /leave/2 returned employee 2's medical-leave note. The search route correctly filters by owner; this route does not.
Impact	Disclosure of colleagues' leave and health-related notes to every employee; a privacy-regulation reportable event if exploited.
Recommendation	Enforce ownership in the query (`WHERE id = ? AND owner = ?`) or allow HR role explicitly; return 404 for records the caller does not own. Add an automated authorisation test using two users for every object route.

Evidence: apps/leave-tracker/app.py line 55

```
54 |                 self.reply(200, rows)
55 |             elif url.path.startswith("/leave/"):
56 |                 row = DB.execute("SELECT id, name, kind, note FROM leave WHERE id = ?", (int(url
```

LV-02 Reset tokens generated with a non-cryptographic RNG	MEDIUM
CVSS	5.9 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N)
Classification	CWE-338 | A02:2021 Cryptographic Failures
Priority / owner / due	P2 | Tomas Lindqvist | 30 days
Detected by	Pipeline (SAST) (rules: SAST-INSECURE-RANDOM)
Description	new_reset_token() uses the random module, which is predictable once enough output is observed.
Impact	Password-reset or invite tokens could be predicted.
Recommendation	Use `secrets.token_urlsafe(32)`, store only a hash of the token, and expire it after 15 minutes.

Evidence: apps/leave-tracker/app.py line 27

```
26 | def new_reset_token():
27 |     return "".join(random.choice(string.ascii_letters + string.digits) for _ in range(16))
28 |
```

LV-03 Stack traces returned to the client	MEDIUM
CVSS	5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
Classification	CWE-209 | A05:2021 Security Misconfiguration
Priority / owner / due	P2 | Tomas Lindqvist | 30 days
Detected by	Pipeline (SAST) (rules: SAST-VERBOSE-ERRORS)
Description	The generic exception handler returns the full Python traceback in the JSON response.
Impact	Discloses code structure, library versions and file paths.
Recommendation	Return a generic message with a correlation id; log the traceback server-side.

Evidence: apps/leave-tracker/app.py line 67

```
66 |         except Exception:  # noqa: BLE001 - deliberately returns the stack trace
67 |             self.reply(500, {"error": traceback.format_exc()})
68 |
```

LV-04 Session cookie lacks Secure and HttpOnly	MEDIUM
CVSS	5.9 (CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:L/A:N)
Classification	CWE-614 | A05:2021 Security Misconfiguration
Priority / owner / due	P2 | Tomas Lindqvist | 30 days
Detected by	Pipeline (SAST) (rules: SAST-COOKIE-FLAGS)
Description	The login stub sets a cookie with only Path=/. Production sessions come from the SSO integration, but the same helper would be reused.
Impact	Cookie can be read by script or sent over plain HTTP.
Recommendation	Set Secure; HttpOnly; SameSite=Lax and a short lifetime.

Evidence: apps/leave-tracker/app.py line 71

```
70 |         if urlparse(self.path).path == "/login":
71 |             return self.reply(200, {"ok": True}, headers=[("Set-Cookie", "session=tok-alice; Pat
72 |         self.reply(404, {"error": "not found"})
```

LV-05 requests 2.25.1 has a known advisory (CVE-2023-32681)	MEDIUM
CVSS	6.1 (CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:C/C:H/I:N/A:N)
Classification	CWE-200 | A06:2021 Vulnerable and Outdated Components
Priority / owner / due	P2 | Tomas Lindqvist | 30 days
Detected by	Pipeline (SCA) (rules: SCA-VULNERABLE-DEPENDENCY)
Description	Proxy-Authorization header can leak to the destination on HTTPS redirects. The package is declared but not yet imported, so there is no current exposure.
Impact	Credential leak if the HRIS client is later built on this version behind a proxy.
Recommendation	Upgrade to requests 2.32.4 or later and turn on Dependabot.

Evidence: apps/leave-tracker/requirements.txt line 1

```
1 | requests==2.25.1
2 | gunicorn==22.0.0
```

LV-06 Missing CSP and X-Frame-Options; no container health check	LOW
CVSS	3.1 (CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:N)
Classification	CWE-693 | A05:2021 Security Misconfiguration
Priority / owner / due	P3 | Tomas Lindqvist | 60 days
Detected by	Pipeline (DAST, container scan) (rules: DAST-MISSING-HEADERS, DOCKER-NO-HEALTHCHECK)
Description	Only X-Content-Type-Options is sent. The image defines no HEALTHCHECK.
Impact	Weaker clickjacking and script-injection defence; failed tasks are not auto-replaced quickly.
Recommendation	Add Content-Security-Policy and X-Frame-Options (or frame-ancestors) and a HEALTHCHECK.

Evidence: apps/leave-tracker/app.py line 34

```
33 |         self.send_header("Content-Type", "application/json")
34 |         self.send_header("X-Content-Type-Options", "nosniff")
35 |         for key, value in headers:
```

LV-07 No audit trail for HR exports	LOW
CVSS	2.7 (CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:N/A:N)
Classification	CWE-778 | A09:2021 Security Logging and Monitoring Failures
Priority / owner / due	P3 | Tomas Lindqvist | 60 days
Detected by	Manual review
Description	The bulk export route is correctly role-restricted but records no event of who exported what and when.
Impact	A malicious or compromised HR account could exfiltrate all leave data without a trace.
Recommendation	Log an audit event for every export and alert on exports outside business hours.

Evidence: apps/leave-tracker/app.py line 58

```
57 |                 self.reply(200 if row else 404, row or {"error": "not found"})
58 |             elif url.path == "/admin/export":
59 |                 if who[1] != "hr_admin":
```

7. OWASP ASVS 4.0.3 coverage

Each chapter was assessed at ASVS level 2 for the controls relevant to this application.

Chapter	Result	Notes
V1 Architecture	**Pass**	Threat model completed in this review.
V2 Authentication	**Partial**	SSO in production; stub in demo.
V3 Session Management	**Partial**	Cookie flags missing.
V4 Access Control	**Fail**	Object-level check missing (LV-01).
V5 Validation and Encoding	**Pass**	Parameterised SQL, integer id parsing.
V6 Stored Cryptography	**Partial**	Reset token RNG.
V7 Error Handling and Logging	**Partial**	Stack traces; no audit log.
V8 Data Protection	**Pass**	Encrypted at rest; classification applied.
V9 Communications	**Pass**	TLS 1.2+ at ALB.
V10 Malicious Code	**Pass**	No secrets or backdoors.
V11 Business Logic	**Pass**	Leave rules enforced.
V12 Files and Resources	**N/A**	Attachments handled by a separate service.
V13 API and Web Service	**Partial**	Auth on all non-health routes; IDOR.
V14 Configuration	**Partial**	One advisory; headers incomplete.

8. Automated pipeline evidence

The demo pipeline ran against this application (run 20261006-173842, commit 9a4fe57). Policy: Acme AppSec release gate (demo).

Stage	Result	Findings	What it checks
Inventory	**PASS**	0	Enumerate files, languages and manifests
Secret scan	**PASS**	0	Regex rules for keys, tokens and credentials (gitleaks-style)
SAST	**WARN**	3	AST rules for injection, crypto and misconfiguration (Semgrep/CodeQL-style)
Dependency scan	**WARN**	1	Pinned packages vs. advisory data (pip-audit/Dependabot-style)
IaC scan	**PASS**	0	Terraform misconfiguration (Checkov/tfsec-style)
Container scan	**PASS**	1	Dockerfile hygiene (Hadolint/Trivy-style)

Stage	Result	Findings	What it checks
SBOM	**PASS**	0	CycloneDX 1.5 bill of materials (Syft-style)
DAST	**PASS**	1	Starts the app and probes it over HTTP (ZAP-style)
Release gate	**PASS**	0	Applies policy.json and dated waivers

Gate: PASS. No blocking findings.

9. Remediation roadmap

When	Action
Before production	Fix and verify LV-01 with a two-user authorisation test.
30 days	Cryptographic RNG, error handling, cookie flags, dependency upgrade (LV-02 to LV-05).
60 days	Security headers, health check, audit logging (LV-06, LV-07).
Ongoing	Keep the pipeline gate enabled; add an authorisation test for each new object route.

10. Sign-off

Role	Name	Decision / acknowledgement	Date
AppSec reviewer	AppSec Review Team (demo)	**Approved with conditions**	2026-09-15
Product owner	Priya Nair	Acknowledged findings and roadmap	2026-09-15
Technical lead	Tomas Lindqvist	Accepts remediation dates	2026-09-15
Risk acceptance	None recorded	No residual risk was formally accepted	-

Appendix: rating scales

CVSS v3.1 base score	Severity	Priority	Meaning
9.0 - 10.0	**Critical**	P0	Fix immediately; blocks release.
7.0 - 8.9	**High**	P0 / P1	Fix before release or go-live.
4.0 - 6.9	**Medium**	P1 / P2	Fix within 30 days (earlier when data is sensitive).
0.1 - 3.9	**Low**	P3	Backlog.
None	**Info**	P3	Observation or hardening advice.